

SC-300 Master Bible

Microsoft Identity and Access Administrator — Complete Exam Preparation Guide

Exam Date: August 1, 2025 | Target: Pass First Attempt

How to use this document: This is your single source of truth for SC-300. It combines your 4-Week Study Plan, Cheat Sheet, Lab Checklist, Documentation Map, and the Advanced Gap-Fill Guide into one structured, sequenced resource. Read it domain by domain. Every section has: concepts → depth → scenarios → labs → references.

● = Foundational (must know cold) ● = Intermediate (scenario-level understanding required) ● = Advanced / Exam trap (high-frequency gotcha on the real exam)

TABLE OF CONTENTS

1. [Exam Overview & Strategy](#)
 2. [4-Week Study Schedule](#)
 3. [Domain 1 — Implement & Manage User Identities \(20-25%\)](#)
 4. [Domain 2 — Authentication & Access Management \(25-30%\)](#)
 5. [Domain 3 — Workload Identities & App Access \(15-20%\)](#)
 6. [Domain 4 — Identity Governance \(25%\)](#)
 7. [Master Quick-Reference Tables](#)
 8. [Top 25 Exam Traps](#)
 9. [Complete Lab Checklist](#)
 10. [Complete Documentation Map](#)
-
-

1. EXAM OVERVIEW & STRATEGY {#exam-overview}

What the Exam Tests

SC-300 does NOT test memorization. It tests your ability to:

- **Design** the right IAM architecture for a given enterprise scenario
- **Choose** between similar features based on requirements
- **Troubleshoot** broken configurations from symptoms

- **Explain** why one approach is better than another under Zero Trust principles

Domain Weightings

Domain	Weight	Priority
Implement & Manage User Identities	20-25%	High
Implement Authentication & Access Management	25-30%	Highest
Plan & Implement Workload Identities & App Access	15-20%	Medium
Plan & Implement Identity Governance	25%	High

Zero Trust Principles — Underpin Every Answer

Microsoft embeds Zero Trust into every SC-300 question. When in doubt, apply these:

- **Verify explicitly** — Always authenticate and authorize based on all available signals (identity, location, device, service, workload, data classification).
- **Use least privilege access** — Limit user access with just-in-time and just-enough-access, risk-based adaptive policies, and data protection.
- **Assume breach** — Minimize blast radius, segment access, encrypt end-to-end, use analytics to get visibility and drive threat detection.

Exam Setup

- 40-60 questions, 150 minutes
 - Question types: Single choice, multiple choice (choose 2/3), drag-and-drop, case studies
 - Passing score: 700/1000
 - Available in English and other languages
 - Delivered via Pearson VUE
-
-

2. 4-WEEK STUDY SCHEDULE {#study-schedule}

Week 1 — User Identities + Hybrid Identity (Domain 1)

Focus: Entra Connect, Cloud Sync, identity models, external identities, custom security attributes

Core Reading

- Hybrid identity (PHS, PTA, Federation)
- Entra Connect vs Cloud Sync
- External Identities (B2B, B2B Direct Connect)
- Custom security attributes
- Administrative units

Hands-on Labs

- ☐ Configure Entra Connect with PHS
- ☐ Configure Cloud Sync
- ☐ Create dynamic groups with complex rules
- ☐ Configure cross-tenant access (inbound/outbound)
- ☐ Add custom security attributes to users
- ☐ Configure a Restricted Management AU
- ☐ Test staging mode failover

Goals by End of Week 1

- You can explain PHS/PTA/Federation differences cold, including which supports Identity Protection
 - You can configure hybrid identity end-to-end including staging mode
 - You understand B2B Collaboration vs B2B Direct Connect and when each applies
 - You can manage custom security attributes including role delegation
 - You understand dynamic AU membership and RMAU behavior
-

Week 2 — Authentication & Access Management (Domain 2)

Focus: Conditional Access, MFA, passwordless, identity protection, hybrid auth

Core Reading

- Conditional Access (all components, Authentication Strengths, device filters)

- Authentication methods (MFA, FIDO2, WHfB, TAP)
- Continuous Access Evaluation (CAE)
- Token protection
- Identity Protection (risk types, remediation vs dismissal)
- Seamless SSO, PHS vs PTA decision

Hands-on Labs

- ☐ Build baseline CA policies (MFA for all, block legacy auth)
- ☐ Configure Authentication Strength (phishing-resistant)
- ☐ Configure CA with device filters
- ☐ Configure sign-in frequency + persistent browser session
- ☐ Configure MFA + passwordless (FIDO2, WHfB)
- ☐ Configure Temporary Access Pass (TAP)
- ☐ Configure risk-based CA (user risk + sign-in risk separate policies)
- ☐ Test risk remediation vs dismissal in Identity Protection
- ☐ Configure CAE and test token revocation timing
- ☐ Configure Seamless SSO

Goals by End of Week 2

- You can design CA policies from scratch for any enterprise scenario
- You understand Authentication Strengths vs plain MFA
- You understand CAE propagation timing and client limitations
- You can differentiate Identity Protection risk policies from CA risk conditions
- You can configure passwordless end-to-end including TAP for bootstrapping
- You can interpret and act on risk events correctly

Week 3 — Workload Identities & App Access (Domain 3)

Focus: App registrations, enterprise apps, app proxy, consent governance, managed identities

Core Reading

- App registrations (delegated vs application permissions, consent)
- Enterprise apps (SSO types, SCIM provisioning)
- Application Proxy (connector groups, pre-auth, SSO modes)
- Consent governance (admin consent workflow)

- Managed identities (system-assigned vs user-assigned)
- Workload identity federation

Hands-on Labs

- ☐ Register an app + configure API permissions (delegated and application)
- ☐ Test user consent vs admin consent behavior
- ☐ Configure admin consent workflow with reviewers
- ☐ Configure SCIM provisioning to an enterprise app
- ☐ Configure SAML SSO for an enterprise app
- ☐ Deploy App Proxy connector
- ☐ Publish an internal app with Entra pre-authentication
- ☐ Configure KCD for App Proxy SSO
- ☐ Enable system-assigned and user-assigned managed identities
- ☐ Assign RBAC roles to managed identity
- ☐ Configure Workload Identity Federation for GitHub Actions

Goals by End of Week 3

- You can explain delegated vs application permissions with effective permission behavior
 - You can configure SSO for enterprise apps (SAML, OIDC, header-based)
 - You understand App Proxy architecture, connector groups, and pre-auth tradeoffs
 - You can govern app consent properly including workflow approval chain
 - You can choose between managed identity types for given scenarios
 - You understand workload identity federation and when to use it over secrets
-

Week 4 — Identity Governance (Domain 4)

Focus: Entitlement management, access reviews, PIM, lifecycle workflows, terms of use

Core Reading

- Entitlement management (catalogs, access packages, connected organizations, SoD)
- Access reviews (scope, decision helpers, auto-apply behavior)
- PIM (eligible vs active, activation settings, approval flow, alerts)
- Lifecycle Workflows (triggers, built-in tasks, custom extensions)
- Terms of Use

Hands-on Labs

- ☐ Create catalogs and access packages
- ☐ Configure connected organizations for external access
- ☐ Configure access package with SoD (incompatible packages)
- ☐ Run group and app access reviews
- ☐ Configure access review with auto-apply enabled and disabled
- ☐ Assign eligible PIM roles with approval + MFA + justification
- ☐ Test PIM activation expiry when approver doesn't respond
- ☐ Configure PIM for Azure roles (separate blade)
- ☐ Build joiner/mover/leaver lifecycle workflows
- ☐ Configure custom task extension (Logic App)
- ☐ Create Terms of Use policy and assign via CA

Goals by End of Week 4

- You can design end-to-end governance including external users
 - You understand PIM activation flow including all steps and timeout behavior
 - You can differentiate PIM for Entra roles vs PIM for Azure roles
 - You can automate lifecycle events with built-in tasks and custom extensions
 - You understand access review auto-apply behavior and denial consequences
 - You can govern external users with access packages and connected organizations
-

Final 3 Days — Exam Prep

Day 1 — Full Domain Review

- Review all CA policies (Domain 2)
- Review hybrid identity models (Domain 1)
- Review app permissions and consent (Domain 3)
- Review governance workflows (Domain 4)
- Re-read the Top 25 Exam Traps section of this document

Day 2 — Practice Tests

- Microsoft Learn free practice assessment (timed)
- MeasureUp SC-300 bank (if available)
- Review every wrong answer — don't just check the correct one, understand why your answer was wrong

Day 3 — Weak Areas Only

- Re-read whichever domains scored below 80% in practice tests
 - Focus on: Conditional Access, Identity Protection, PIM, Lifecycle Workflows
 - Do a final pass of the Quick-Reference Tables in this document
-
-

3. DOMAIN 1 — IMPLEMENT & MANAGE USER IDENTITIES (20-25%) {#domain-1}

3.1 Identity Models — Hybrid Authentication

● Password Hash Synchronization (PHS)

- Entra Connect syncs a **hash of the hash** of the user's password to Entra ID — the actual password never leaves on-premises
- Authentication occurs **entirely in the cloud** — no on-premises dependency at sign-in time
- Supports: Conditional Access, Identity Protection (full fidelity including leaked credential detection), SSPR
- **Best for:** Organizations wanting simplicity, cloud resilience, and full Identity Protection capability
- **Enables:** Leaked credential detection (unique to PHS — Microsoft compares your hashed passwords against known breach databases)

● Pass-Through Authentication (PTA)

- A lightweight agent on-premises validates passwords against AD in real time
- Authentication request passes through the cloud to on-premises — **on-premises dependency at sign-in**
- If all PTA agents go down, users cannot sign in (unless PHS is also enabled as backup)
- Does NOT enable leaked credential detection in Identity Protection
- **Best for:** Organizations that cannot allow password hashes in the cloud for compliance reasons

● Federation (AD FS)

- Authentication handled entirely by AD FS on-premises — Entra ID trusts the AD FS token
- Most complex, highest infrastructure overhead
- Supports advanced claims transformation
- **Decommissioning path:** Microsoft recommends migrating to PHS (not PTA) for cloud resilience and full Identity Protection

● Key Comparison Table

Feature	PHS	PTA	Federation
Auth location	Cloud	On-premises (agent)	On-premises (AD FS)
Cloud resilience	✓ Full	✗ Agent required	✗ AD FS required
Identity Protection (leaked credentials)	✓ Yes	✗ No	✗ No
Seamless SSO compatible	✓ Yes	✓ Yes	N/A
Complexity	Low	Medium	High
Password never leaves on-prem	✗ Hash synced	✓ Yes	✓ Yes

 <https://learn.microsoft.com/entra/identity/hybrid/connect/choose-ad-authn>

3.2 Entra Connect Sync

● Core Architecture

- Installed on a Windows Server on-premises
- Synchronizes AD objects (users, groups, contacts, devices) to Entra ID
- **Only one active Connect Sync server per tenant** (additional servers must be in staging mode)
- Sync cycle: default every 30 minutes (delta sync); full sync on demand

● Staging Mode

- A second Connect server that imports and syncs locally but **does not export to Entra ID**
- Used for: disaster recovery, testing configuration changes
- To promote staging server to active: run the wizard and **disable staging mode** — no reinstall, no config import needed
- The staging server already has a current connector space — it just needs exports enabled

● Accidental Deletion Prevention

- Blocks any sync cycle where pending **deletes exceed the threshold** (default: **500 objects**)
- The export halts; admin must explicitly confirm with `Enable-ADSyncExportDeletionThreshold` PowerShell cmdlet
- Configurable threshold — set lower in environments with smaller directories

● Attribute Precedence & Conflict Resolution (Multi-Forest)

- When the same user exists in multiple forests, precedence rules in the **metaverse** determine which forest wins per attribute
- Default precedence set at install time; customizable in **Synchronization Rules Editor**
- **Source Anchor:** `ms-DS-ConsistencyGuid` (preferred) or `objectGUID` — must be unique across forests
- Misconfigured precedence = wrong attribute values win = CA dynamic groups malfunction

● Soft Match vs Hard Match

- **Soft match:** Links cloud user to on-premises object via `proxyAddresses` or `userPrincipalName` — used during initial hybrid setup
- **Hard match:** Uses `ImmutableID` (base64-encoded objectGUID) — required when soft match fails or for recovery scenarios
- **Collision risk:** If a cloud user and a synced object represent the same person without `ImmutableID` alignment, they create duplicate accounts

 <https://learn.microsoft.com/entra/identity/hybrid/connect/how-to-connect-syncservice-duplicate-attribute-resiliency> 

<https://learn.microsoft.com/entra/identity/hybrid/connect/how-to-connect-sync-feature-prevent-accidental-deletes>

3.3 Entra Cloud Sync

● Core Architecture

- Lightweight **provisioning agent** installed on-premises (not a full sync server)
- Provisioning logic runs in the **cloud** — agent just bridges the connection
- Multiple agents = high availability (no staging mode concept)
- Outbound HTTPS only — no inbound firewall ports required (Zero Trust network alignment)

● When to Use Cloud Sync vs Connect

Scenario	Use Cloud Sync	Use Entra Connect
New acquisition, minimal infra	✓	
Multiple forests → one tenant	✓	
Exchange hybrid required		✓
Device writeback required		✓
Group writeback required		✓
Complex attribute mapping		✓
SSPR password writeback	✓ (with SSPR)	✓
Both can coexist in same tenant	✓	✓

● Cloud Sync Limitation Table (Exam Trap)

Feature	Entra Connect	Cloud Sync
Group writeback	✓ Yes (v2)	✗ No
Device writeback	✓ Yes	✗ No
Exchange hybrid writeback	✓ Yes	✗ No
Password writeback (SSPR)	✓ Yes	✓ Yes
Provisioning to multiple tenants	✗ No	✓ Yes

Feature	Entra Connect	Cloud Sync
Attribute mapping customization	Full	Limited

 <https://learn.microsoft.com/entra/identity/hybrid/cloud-sync/what-is-cloud-sync>

3.4 User & Group Management

● Dynamic Security Groups

- Membership driven by attribute rules — no manual adds allowed
- Re-evaluated when: user attribute changes, rule is modified, manual trigger via PowerShell
- Processing time: up to **24 hours** for large tenants — not suitable for time-critical access

● Dynamic Group Rule Operators — Case Sensitivity Trap

Operator	Case Sensitive?	Notes
<code>-eq</code>	Yes (for synced attrs)	"Finance" ≠ "finance"
<code>-ne</code>	Yes	Opposite of -eq
<code>-contains</code>	No	"Sr. Analyst" matches -contains "Analyst"
<code>-match</code>	No	Regex, case-insensitive
<code>-startsWith</code>	No	

Exam trap: On-premises AD attributes synced to Entra are case-preserved. A rule with `user.department -eq "Finance"` will NOT match a user with `department = "finance"` (lowercase) synced from AD.

● Dynamic Groups Cannot

- Have members manually added
- Be used as role-assignable groups
- Be used as security groups for on-premises resource access (cloud-only)
- Have a syntax error without stopping all evaluation (broken rule = no updates for entire group)

3.5 Administrative Units (AUs)

● Standard AUs

- Container for scoping admin roles to a subset of users, groups, or devices
- Example: scope User Administrator role to only the Germany AU → admin can only manage German users
- Membership: static (manual) or dynamic (attribute rule, users only — not groups or devices)

● Restricted Management AUs (RMAUs)

- **Even Global Admins are blocked** from managing objects in an RMAU unless explicitly scoped to it
- Use case: break-glass accounts, VIP executives, high-value service accounts
- This is by design — if a Global Admin gets an "Insufficient privileges" error on an RMAU object, that is expected behavior
- To grant access: assign a role explicitly scoped to the RMAU

● Dynamic AU Membership Rules

- Only **users** support dynamic membership in AUs (devices and groups cannot)
- Same ~24-hour processing delay as dynamic groups
- Rule syntax identical to dynamic groups

 <https://learn.microsoft.com/entra/identity/role-based-access-control/admin-units-restricted-management>  <https://learn.microsoft.com/entra/identity/role-based-access-control/administrative-units>

3.6 External Identities

● B2B Collaboration

- External users invited as **guests** — a guest account is created in your tenant
- Governed by your tenant's CA policies, PIM, access packages
- Invite control: configured in External Collaboration Settings
 - Allow all users to invite

- Only Guest Inviter role + certain admins
- Only specific admin roles
- Block all invitations
- Domain allow/deny list: controls which external domains can be invited

● B2B Direct Connect

- No guest account created in your tenant
- Used exclusively for **Teams shared channels**
- Configured via cross-tenant access inbound/outbound settings
- NOT governed by access packages
- NOT fully governed by your CA policies (limited)

● B2B Comparison Table

	B2B Collaboration	B2B Direct Connect
Guest account in tenant	✓ Yes	✗ No
CA policies apply	✓ Full	⚠ Limited
PIM eligible	✓ Yes	✗ No
Access packages	✓ Yes	✗ No
Use case	General guest access	Teams shared channels only

● Cross-Tenant Access Trust Settings

- You can configure your tenant to **trust MFA claims** from a specific partner tenant
- If their tenant completed MFA, your CA MFA requirement is satisfied — no second MFA prompt
- You can also trust: **Compliant device** and **Hybrid Azure AD Joined** device claims from partners
- This is configured in Entra ID → External Identities → Cross-tenant access settings → [Partner tenant] → Inbound trust settings

 <https://learn.microsoft.com/entra/external-id/cross-tenant-access-overview> 

<https://learn.microsoft.com/entra/external-id/allow-deny-list>

3.7 Custom Security Attributes

● Basics

- Custom key-value pairs stored on user, application, or service principal objects
- Organized into **attribute sets** — each set contains one or more attributes
- Values are NOT visible to all users — access is controlled by role assignment
- Can be used in Azure ABAC (attribute-based access control for Azure resources)

● Role Requirements

- **Attribute Definition Administrator:** Creates and manages attribute sets and attribute definitions
- **Attribute Assignment Administrator:** Assigns attribute values to users and apps
- These are separate roles — defining an attribute and assigning values to users require different permissions

● What Custom Security Attributes Are NOT

- NOT usable in dynamic group membership rules (use extensionAttributes for that)
- NOT visible to regular users or apps without explicit role assignment
- NOT the same as directory extension attributes (extensionAttribute1-15) which are globally readable

 <https://learn.microsoft.com/entra/fundamentals/custom-security-attributes-overview>

3.8 HR-Driven Provisioning (Workday → AD)

● Architecture

1. **Workday** (HR source of truth)
2. **Entra provisioning service** (cloud, handles attribute mapping and OU targeting)
3. **Entra Connect provisioning agent** (on-premises, bridges cloud service to AD — different from Cloud Sync agent)
4. **On-premises Active Directory** (user objects created here)
5. **Entra Connect Sync** (syncs AD objects up to Entra ID)

● Key Distinctions

- **Entra provisioning service + Connect provisioning agent** = Workday → AD (inbound)

to on-prem)

- **Entra Connect Sync** = AD → Entra ID (upward to cloud)
- **Cloud Sync agent** = AD → Entra ID (alternative to Connect Sync)
- **Lifecycle Workflows** = post-provisioning tasks (welcome email, TAP generation, group membership) — they do NOT create AD objects
- **MIM 2016** = legacy solution, no longer recommended

 <https://learn.microsoft.com/entra/identity/saas-apps/workday-inbound-tutorial>

3.9 Stale Guest Lifecycle Management

● Two-Tool Approach

1. **Identification:** Stale guest account report in Identity Governance blade (uses `signInActivity` property via Graph API)
2. **Remediation:** Access review of guest users with "Block from signing in and delete within 30 days" action upon denial

● Access Review Automation Options

- Set "No action = Deny" (not the default — default is "No response = Approve")
- Enable auto-apply results so denials take effect immediately when review closes
- Without auto-apply, results sit pending until manually applied

 <https://learn.microsoft.com/entra/identity/users/clean-up-stale-guest-accounts>

4. DOMAIN 2 — AUTHENTICATION & ACCESS MANAGEMENT (25-30%) {#domain-2}

4.1 Conditional Access — Complete Reference

● Policy Anatomy

Assignments (WHO and WHAT):

- Users and groups (include/exclude)
- Cloud apps or actions (include/exclude)

- Conditions (when to apply)

Conditions:

- Sign-in risk (Identity Protection signal)
- User risk (Identity Protection signal)
- Device platforms (iOS, Android, Windows, macOS)
- Locations (named locations, all trusted, all compliant)
- Client apps (browser, mobile apps, Exchange ActiveSync, other clients)
- Device filters (rule-based expression)
- Authentication context

Access Controls:

- Grant: Block, Require MFA, Require Authentication Strength, Require compliant device, Require Hybrid Azure AD Joined, Require approved client app, Require app protection policy, Require password change
- Session: Sign-in frequency, Persistent browser session, App-enforced restrictions, Cloud app security (MCAS), Token protection

● Always Test with Report-Only First

- Report-only policies evaluate but do NOT enforce
- They generate sign-in log entries showing what WOULD have happened
- Skip this step in production and you risk locking users out
- Never deploy an "All users / All apps / Block" policy directly to enabled

● High-Yield CA Policies (Must Know All of These)

Policy	Assignment	Condition	Grant
Require MFA for all users	All users	—	Require MFA
Block legacy authentication	All users	Client apps: Exchange ActiveSync + Other	Block
Require compliant device for admins	Directory roles (privileged)	—	Require compliant device OR Hybrid AADJ
Block high user risk	All users	User risk: High	Block (or Require password change)

Policy	Assignment	Condition	Grant
Require MFA for medium sign-in risk	All users	Sign-in risk: Medium/High	Require MFA
Terms of Use for external users	Guest users	—	Require Terms of Use acceptance
Require phishing-resistant MFA for privileged roles	Privileged roles	—	Require Authentication Strength: Phishing-resistant

● Authentication Strengths (High-Frequency Gap)

Authentication Strengths define **which specific authentication methods** satisfy a CA grant control. More precise than "Require MFA."

Built-in strengths:

Strength	Methods that satisfy it
Multifactor authentication	Any combination: password + any MFA method
Passwordless MFA	Microsoft Authenticator (passwordless), FIDO2, WHfB
Phishing-resistant MFA	FIDO2 security keys, Windows Hello for Business, Certificate-based auth ONLY

Key exam distinction:

- Microsoft Authenticator push notification satisfies **MFA** and **Passwordless MFA** but NOT **Phishing-resistant MFA**
- Only FIDO2, WHfB, and CBA satisfy phishing-resistant strength
- Custom strengths: you can create your own (e.g., "FIDO2 or WHfB only")

 <https://learn.microsoft.com/entra/identity/authentication/concept-authentication-strengths>

● Device Filter Conditions

Filters use **rule expression syntax** on device attributes:

Filter Expression	Meaning
<code>device.trustType -eq "ServerAD"</code>	Hybrid Azure AD Joined devices only
<code>device.isCompliant -eq True</code>	Compliant devices only
<code>device.deviceId -in ["id1","id2"]</code>	Specific device IDs
<code>device.extensionAttribute1 -eq "PAW"</code>	Custom attribute value

- You can **include or exclude** devices matching the filter in a single policy
- Example: Apply stricter controls to all devices where `device.isCompliant -ne True`

 <https://learn.microsoft.com/entra/identity/conditional-access/concept-condition-filters-for-devices>

● Sign-in Frequency vs Persistent Browser Session

These are two distinct session controls, frequently confused:

Control	What It Does	Exam Scenario
Sign-in frequency	Forces re-auth after N hours/days regardless of session activity	Admins re-authing every hour → too aggressive
Persistent browser session	Controls "Stay signed in?" behavior after browser close	Users signed out every time they close browser

- Setting sign-in frequency to **Every time** = re-auth on every new session (use for PAWs, privileged roles)
- "Always persistent" + short sign-in frequency = frequent MFA prompts (common misconfiguration)

● Named Locations vs Trusted Locations

- **Named location:** IP range or country that you define in CA for use in location

conditions

- **Mark as trusted:** Checkbox on a named location that reduces the sign-in risk score for sign-ins from that IP
- **Trusted IPs (legacy MFA):** Per-user MFA setting bypassing MFA from specific IPs — legacy, not CA
- **Important:** Marking a location as trusted does NOT bypass CA policies — it only influences the **risk score signal**. You must create an explicit CA exclusion to bypass CA enforcement.

 <https://learn.microsoft.com/entra/identity/conditional-access/location-condition>

● CA for Workload Identities (Service Principals)

- CA policies can target **service principals** (app identities), not just users
- Available conditions for workload identities: **IP location only** (no device, no user risk)
- Use case: restrict which IPs a daemon application can authenticate from
- Configured in: CA blade → New policy → Users → Workload identities

 <https://learn.microsoft.com/entra/identity/conditional-access/workload-identity>

4.2 Continuous Access Evaluation (CAE)

● What CAE Solves

Normally, access tokens are valid for 60–90 minutes. If a user is disabled at 2:00 PM, they can still access resources until their token expires. CAE enables near-real-time revocation.

● How It Works

- CAE-capable apps (Exchange Online, SharePoint, Teams, Microsoft Graph) **subscribe to events** from Entra ID
- When a critical event occurs, the resource provider immediately requests a new token
- If the new token request fails (account disabled, session revoked), access is blocked

● Events That Trigger Revocation

- User account disabled or deleted
- User password changed or reset
- Admin revokes all user sessions
- User location changes outside trusted IPs (if IP-binding enabled)

- High-risk user detected by Identity Protection

● CAE Limitations

- Only works with **CAE-capable clients** — modern Office apps, supported browsers
- Legacy clients (SMTP, IMAP, older Outlook versions) do NOT support CAE — tokens remain valid until expiry
- Revocation propagation: up to **15 minutes** (near real-time, not instant)
- If a user is still accessing resources 5-10 minutes after account disable, this is normal CAE behavior — investigate after 15+ minutes

 <https://learn.microsoft.com/entra/identity/conditional-access/concept-continuous-access-evaluation>

4.3 Token Protection

● What It Does

- Binds the token to the specific device it was issued to
- Prevents **token theft/replay attacks** — even if an attacker extracts a token, they cannot use it from a different device
- Configured as a CA session control: Session → Token protection

● Requirements

- Only works with supported apps and platforms (primarily Windows with specific apps)
- Enabling token protection on unsupported apps/platforms will block those users
- Always test with Report-Only first

 <https://learn.microsoft.com/entra/identity/conditional-access/concept-token-protection>

4.4 Authentication Methods

● Passwordless Methods

Method	Security Level	Best For	Notes
FIDO2 Security Key	Highest (phishing-resistant)	High-security users, shared workstations	Hardware key required
Windows Hello for Business	Highest (phishing-resistant)	Windows domain-joined devices	Biometric or PIN
Microsoft Authenticator (passwordless)	High	Mobile-first users	Push notification, number matching
Temporary Access Pass (TAP)	Bootstrap only	New hire onboarding, recovery	Time-limited, single-use by default

● TAP Behavior

- **Single-use by default** — after use, must register a permanent method
- Configurable: multi-use for specific scenarios
- Default expiry: 1 hour (configurable)
- Use case: bootstrap MFA registration for new hires in Lifecycle Workflows

● FIDO2 Attestation Restrictions

- Organizations can restrict which FIDO2 keys are allowed using **AAGUID** (authenticator attestation GUID)
- Example: Allow only YubiKey 5 Series, block unverified cheap keys
- Configured in: Authentication Methods → FIDO2 security key → Advanced options

● WHfB Deployment Models

Model	Requirements	Use Case
Cloud-only	Entra ID joined devices	Pure cloud org
Hybrid — Cloud Trust	Entra Connect + no PKI needed	Recommended for hybrid

Model	Requirements	Use Case
Hybrid — Certificate Trust	Entra Connect + on-prem PKI	Legacy hybrid deployments
On-premises	AD + PKI only	No cloud dependency

Cloud Trust eliminates the need for on-premises PKI by using Entra ID as the trust anchor — Microsoft's current recommended model for hybrid WHfB.

 <https://learn.microsoft.com/entra/identity/authentication/concept-passwordless> 
<https://learn.microsoft.com/entra/identity/authentication/howto-authentication-temporary-access-pass>

4.5 Identity Protection

Risk Types

Type	What It Measures	When Evaluated
Sign-in risk	Probability that THIS sign-in attempt is not from the legitimate user	Real-time at sign-in
User risk	Probability that the user's account is compromised	Accumulates over time (offline detections)

Real-Time vs Offline Detections

Detection	Type	Example
Anonymous IP address	Real-time	Tor browser, anonymizing proxy
Unfamiliar sign-in properties	Real-time	New location/device for that user
Malware-linked IP	Real-time	Known botnet IP
Impossible travel	Offline	Sign-in from NYC then London 30 min later
Leaked credentials	Offline	Password found in breach database (PHS only)
Password spray	Offline	Multiple failed attempts across accounts

Why this matters for CA design:

- CA sign-in risk policy catches **real-time** detections at the moment of sign-in
- CA user risk policy catches **offline** detections that elevate user risk after the fact
- You need BOTH policies for full coverage — relying only on sign-in risk leaves compromised accounts unblocked after offline detections fire

● Remediation vs Dismissal vs Confirm Compromise

Action	Effect	When to Use
Remediate (user resets password)	Clears user risk	Genuine compromise — credential changed
Dismiss risk	Closes risk entry without remediation	Confirmed false positive
Confirm compromise	Elevates risk, triggers additional controls	SOC confirmed actual attack

Critical: Dismissing a risk does NOT change the password or revoke sessions. If the account was actually compromised, the attacker may still have access.

● Identity Protection Policies vs CA Risk Conditions

Microsoft's **current recommendation:** Disable the legacy Identity Protection risk policies and use CA **policies with risk conditions** instead.

	Legacy IP Policies	CA with Risk Conditions (Recommended)
Location	Identity Protection blade	CA blade
Flexibility	Low (block or MFA only)	High (any CA control)
Scope	All users or targeted	Fully scoped
Recommended	No (deprecated path)	Yes

 <https://learn.microsoft.com/entra/id-protection/concept-identity-protection-risks>  <https://learn.microsoft.com/entra/id-protection/overview-identity-protection>

4.6 Seamless SSO

● What It Does

- Users on domain-joined machines in the corporate network are signed in automatically to cloud apps without re-entering credentials
- Works with both PHS and PTA (not needed with federation — AD FS handles SSO natively)
- Uses Kerberos ticket from on-premises AD to obtain Entra ID token

● Configuration Requirements

- Entra Connect: enable Seamless SSO in the wizard
- Deploy a Kerberos computer account in each AD forest (`AZUREADSSOACC`)
- Add `https://autologon.microsoftazuread-sso.com` to the Intranet zone in IE/Edge Group Policy

 <https://learn.microsoft.com/entra/identity/hybrid/connect/how-to-connect-sso>

5. DOMAIN 3 — WORKLOAD IDENTITIES & APP ACCESS (15-20%) {#domain-3}

5.1 App Registrations

● Core Concepts

- An **app registration** = the identity of your application in Entra ID
- Creates two objects: the **Application object** (home tenant, global) and a **Service Principal** (in each tenant where the app is used)
- Every app that integrates with Entra ID must be registered

● Permission Types

Type	User Present?	Effective Permission	Admin Consent Required?
Delegated	Yes	Intersection of user's permissions AND app's permissions	Not always
Application	No (daemon/service)	Full granted permission	Always

Exam trap: Delegated permission is bounded by what the signed-in user can do. An app with `Mail.Read` delegated cannot read another user's mail — it can only read the signed-in user's mail (and only if that user has a mailbox).

● Client Credentials

- **Client secrets:** Password-like strings; short-lived; exam always recommends certificates instead
- **Certificates:** More secure; no plaintext secret; preferred by Microsoft and the exam
- **Workload identity federation:** Eliminates secrets entirely for supported external IdPs

● Redirect URIs

- Required for OAuth 2.0 / OIDC flows (authorization code flow, implicit flow)
- Must exactly match what the application sends in the auth request
- Not required for client credentials flow (no user redirect)

 <https://learn.microsoft.com/entra/identity-platform/concept-register-app>

5.2 Consent Framework

● Consent Types

Type	Who Consents	When
User consent	Individual user	Low-sensitivity delegated permissions (if user consent enabled)
Admin consent (tenant-wide)	Admin on behalf of all users	High-sensitivity or application permissions

● Admin Consent Workflow

When users request permissions requiring admin consent:

1. User is blocked at sign-in with a request form
2. Request sent to designated **reviewers** (configured in Enterprise Apps → User settings → Admin consent requests)
3. Reviewer approves or denies in the portal
4. User notified of outcome

Exam trap: Reviewers are configured **tenant-wide**, not per-app. Setting a reviewer applies to all admin consent requests unless further scoped.

● Consent on Behalf of Organization

- When admin grants tenant-wide consent, a permission grant is added to the **service principal** for that app
- Revoking: delete the permission grant on the enterprise app's service principal, or remove the enterprise app entirely
- Even after revoking, if user consent is re-enabled, users could re-consent for delegated permissions

 <https://learn.microsoft.com/entra/identity-platform/howto-configure-admin-consent-workflow>  <https://learn.microsoft.com/entra/identity-platform/permissions-consent-overview>

5.3 Enterprise Applications

● SSO Types

SSO Type	How It Works	Best For
SAML	Token-based federation, Entra issues SAML assertion	Most SaaS apps
OIDC	OpenID Connect, Entra issues ID token	Modern apps
Password-based	Entra injects credentials into app	Legacy apps with no SSO support
Linked	Just a link in My Apps — no actual SSO	Informational links

SSO Type	How It Works	Best For
Header-based	App Proxy injects HTTP headers	Legacy apps using header auth

● SCIM Provisioning

- Automates user lifecycle (create, update, disable, delete) in SaaS apps
- Entra ID pushes changes to the app's SCIM endpoint
- Attribute mappings configurable
- Provisioning scope: assigned users/groups only, or all users

 <https://learn.microsoft.com/entra/identity/enterprise-apps/what-is-application-management>  <https://learn.microsoft.com/entra/identity/app-provisioning/use-scim-to-provision-users-and-groups>

5.4 Application Proxy

● Architecture

- Publishes on-premises web apps to external users without a VPN
- **Connector:** Lightweight agent installed on-premises (Windows Server) — outbound HTTPS only
- **Pre-authentication:** Entra ID authenticates the user before the request reaches the on-premises app
- Traffic flow: User → Entra App Proxy service (cloud) → Connector → Internal app

● Connector Groups

- Group connectors by location or purpose
- Each published app is assigned to a connector group
- A connector group must have at least one **active connector** for the app to be accessible
- Use case: European apps routed through European connectors for lower latency

● Pre-Authentication Methods

Method	CA Enforced?	When to Use
Entra ID (default)	 Yes	All apps where Entra auth is possible

Method	CA Enforced?	When to Use
Passthrough	✗ No	Apps with their own auth, legacy systems

Critical: Passthrough pre-auth = **no CA enforcement**. Anyone with the external URL can reach the app's login page directly.

● SSO Modes for App Proxy

Mode	Requirement	When to Use
Kerberos Constrained Delegation (KCD)	Connector domain-joined + SPN configured	Windows Integrated Auth apps
Header-based	App reads HTTP headers	Apps using header-based auth
SAML	SAML-capable app	Federated apps
Password-based	—	Last resort for legacy apps
None	—	App handles its own auth

 <https://learn.microsoft.com/entra/identity/app-proxy/application-proxy> 

<https://learn.microsoft.com/entra/identity/app-proxy/application-proxy-connector-groups>

5.5 Managed Identities

● Types

Type	Lifecycle	Sharing	Use Case
System-assigned	Tied to the Azure resource	One resource only	Single resource needing identity
User-assigned	Independent resource	Multiple resources	Many resources sharing same permissions

● When to Use User-Assigned

If 50 Azure Functions all need access to the same Key Vault:

- Create ONE user-assigned managed identity
- Assign Key Vault Reader role to it
- Assign that identity to all 50 functions
- One RBAC assignment vs 50 separate ones with system-assigned

● Managed Identity Limitations

- Can ONLY authenticate to services that support Azure AD authentication
- Relies on the **Azure Instance Metadata Service (IMDS)** — only available inside Azure
- **Cannot be used outside Azure** (no on-premises, no other clouds, no external workloads)
- For non-Azure workloads: use **Workload Identity Federation** instead

 <https://learn.microsoft.com/entra/identity/managed-identities-azure-resources/overview>

5.6 Workload Identity Federation

● What It Solves

Eliminates long-lived client secrets/certificates in CI/CD pipelines and external workloads by establishing a trust relationship between Entra ID and an external IdP.

● How It Works

1. Register an app in Entra ID
2. Configure a **federated credential** on the app (points to external IdP's OIDC issuer — e.g., GitHub, Kubernetes, AWS)
3. External workload gets a token from its own IdP (GitHub Actions OIDC token)
4. Exchanges that token for an Entra ID access token — no secret required

● Supported External IdPs

- GitHub Actions
- Kubernetes (AKS, or any OIDC-compliant K8s)
- AWS
- Google Cloud

6. DOMAIN 4 — IDENTITY GOVERNANCE (25%) {#domain-4}

6.1 Entitlement Management

Core Components

Catalog: A container that groups related resources (apps, groups, SharePoint sites) together. Each catalog has owners who manage what resources are in it.

Access Package: A bundle of resources from a catalog. Users request access to the package, not individual resources. A single package can contain multiple apps, groups, and sites.

Policy: Defines who can request the access package, approval requirements, and lifecycle (expiration, access reviews).

Connected Organization: An external organization whose users can request access packages. Linked to the organization's Entra tenant or domain.

Access Package Policy Types

Policy Type	Who Can Request
For users in your directory	Members, existing guests
For users not in your directory	External users via connected org
None (admin assignment only)	Only admins can assign directly

Separation of Duties (SoD) — Incompatible Packages

- You can mark two access packages as **incompatible** with each other
- If a user holds Package A, they cannot request Package B
- Use case: "Approve Purchase Orders" and "Create Purchase Orders" packages are incompatible
- This is a **native, built-in control** — no custom logic required

● Connected Organization ≠ Cross-Tenant Access Policy

- **Connected organizations:** Entitlement Management feature — defines which external orgs can request access packages
- **Cross-tenant access policies:** Identity security feature — defines B2B trust, MFA trust, inbound/outbound collaboration rules
- These are **completely separate configurations** that serve different purposes

 <https://learn.microsoft.com/entra/id-governance/entitlement-management-access-packages>  <https://learn.microsoft.com/entra/id-governance/entitlement-management-access-package-incompatible>  <https://learn.microsoft.com/entra/id-governance/entitlement-management-connected-orgs>

6.2 Access Reviews

● What Can Be Reviewed

- Group membership
- Application assignments
- Privileged role assignments (PIM roles)
- Guest user access

● Review Scope Options

Scope	What Is Reviewed
All members	Every user in the group/app
Guest users only	Only B2B guests
Inactive users	Users who haven't signed in for N days

● Decision Helpers

- **System recommendations:** Entra recommends approve/deny based on sign-in activity (inactive users get a deny recommendation)
- Reviewers can accept recommendations with one click — reduces review burden

● "No Response" Default Behavior — Exam Trap

Setting	Behavior	Security Impact
No action = Approve (default)	Unreviewed access stays	✗ Security risk — stale access persists
No action = Deny (recommended)	Unreviewed access removed	✓ Least privilege maintained

Always configure "No response = Deny" for security-sensitive reviews.

● Auto-Apply Results — Critical Distinction

- **Auto-apply disabled (default):** Review completes, results sit pending, **admin must manually apply** them
- **Auto-apply enabled:** Denied access is removed immediately when the review period closes

Exam scenario: 50 guests denied in a review. 7 days later all 50 accounts still active. Cause: auto-apply was not enabled.

● Upon Denial — What Happens

Object Type	Upon Denial
Group member	Removed from group
App assignment	Removed from application
Guest user (if selected)	Block sign-in → delete after 30 days
Eligible PIM role	Role assignment removed

 <https://learn.microsoft.com/entra/id-governance/access-reviews-overview>

6.3 Privileged Identity Management (PIM)

● Assignment Types

Type	Behavior	Use Case
Eligible	User must activate the role — NOT currently active	All privileged roles (default choice)
Active (time-bound)	Role is active for a defined period	Short-term projects
Active (permanent)	Role is always active — never expires	Break-glass only, service accounts

Zero Trust principle: All privileged roles should be **eligible**, not permanently active. Permanent active assignments = PIM alert.

● Activation Settings Per Role

Each role has configurable activation requirements:

- **Maximum activation duration:** 1-24 hours — role deactivates automatically
- **Require MFA on activation:** Even if already MFA'd for the session
- **Require justification:** Business reason text entry
- **Require ticket information:** ITSM ticket number
- **Require approval:** One or more designated approvers must approve

● PIM Activation Flow

```
User requests activation
    ↓
MFA required? → Complete MFA
    ↓
Justification required? → Enter reason
    ↓
Ticket number required? → Enter ticket
    ↓
Approval required?
    YES → Request sent to approver(s)
        ↓
        Approver responds within timeout?
            YES → Role activates for configured duration
```

NO → Request EXPIRES and is auto-denied
NO → Role activates immediately for configured duration
↓
Duration expires → Role automatically deactivates
User returns to eligible-only status

● Approval Timeout vs Activation Duration

- **Pending approval timeout:** How long a request waits for approver response before auto-denying (default: 24 hours, configurable)
- **Activation duration:** How long the role stays active after approval (1-24 hours per role config)
- These are separate — a 1-hour activation duration does NOT mean approvals expire in 1 hour

● PIM for Entra Roles vs PIM for Azure Roles

	PIM for Entra Roles	PIM for Azure Roles
Blade location	Entra ID → Roles and administrators	Azure → PIM → Azure resources
Scope	Tenant-wide directory roles	Azure subscriptions, resource groups, resources
Activation	Through Entra PIM portal	Through Azure PIM portal
Audit logs	Entra audit log	Azure Activity log

These are different features in different portals. The exam tests whether you know which blade handles which role type.

● PIM Alerts — Must Know

Alert	Meaning
Too many Global Admins	Microsoft recommends 2-4 max
Permanent active role assignments	All privileged roles should be eligible
Roles don't require MFA on activation	Security gap
Roles being activated too frequently	Possible misuse or process gap

Alert	Meaning
Duplicate role assignments	Same role eligible AND active for same user

<https://learn.microsoft.com/entra/id-governance/privileged-identity-management/pim-configure>
<https://learn.microsoft.com/entra/id-governance/privileged-identity-management/pim-resource-roles-assign-roles>

6.4 Lifecycle Workflows

● What Lifecycle Workflows Do

Automate identity tasks triggered by HR events or schedule. They do NOT create accounts — they run tasks on existing accounts.

Joiner → Mover → Leaver is the core pattern.

● Trigger Types

Trigger	When It Fires	Example
Time-based (relative to attribute)	N days before/after a date attribute	7 days before <code>employeeHireDate</code>
On-demand	Manually triggered	Testing or one-off exceptions
Attribute change (real-time)	When a specific attribute changes	<code>department</code> change triggers mover

● Built-in Workflow Templates

Category	Template	Purpose
Joiner	Pre-hire onboarding	Tasks before start date
Joiner	New hire onboarding	Tasks on/after start date
Mover	Department change	Access adjustments
Leaver	Last day	Disable, remove access
Leaver	Post-offboarding	Delete, remove licenses

● Built-in Tasks (Must Know All)

- Enable user account
- Disable user account
- Delete user account
- Add user to group
- Remove user from group
- Remove user from all groups
- Remove user from all Teams
- Send welcome email
- Send offboarding email
- Generate Temporary Access Pass — critical for joiner workflow; new hires bootstrap MFA with TAP
- Assign licenses
- Remove licenses

● Custom Task Extensions

When built-in tasks aren't enough:

- Register a **Logic App** as a custom task extension in the workflow
- The Logic App is called synchronously or asynchronously
- Use case: provision account in ServiceNow, create ITSM ticket, notify HR system, provision non-SCIM systems

● Lifecycle Workflows ≠ Provisioning

- **Lifecycle Workflows:** Run tasks on existing identity objects (enable, disable, add to group, send email)
- **Provisioning service:** Creates and manages identity objects in target systems (Workday → AD, AD → Entra)
- They are complementary, not interchangeable

 <https://learn.microsoft.com/entra/id-governance/workflows-overview>

6.5 Terms of Use

● Basics

- Upload a PDF document that users must accept before accessing resources
- Enforced via a CA grant control: "Require Terms of Use acceptance"
- Acceptance records are tracked and reportable
- Can be configured per-language and per-version

● Use Cases

- External guest users accepting collaboration terms before accessing tenant resources
- Regulatory compliance acknowledgements
- Acceptable use policies for all employees on first sign-in

● Configuration

- Create Terms of Use policy: Entra ID → Identity Governance → Terms of Use
- Assign via CA: create a CA policy targeting desired users → Grant → Require Terms of Use

 <https://learn.microsoft.com/entra/id-governance/terms-of-use>

7. MASTER QUICK-REFERENCE TABLES {#quick-reference}

Hybrid Authentication Decision

Requirement	Choose
Simplest setup, cloud resilience	PHS
Leaked credential detection (Identity Protection)	PHS (only option)
Password never stored in cloud (compliance)	PTA or Federation
Advanced claims transformation	Federation (AD FS)
Decommissioning AD FS	Migrate to PHS

Requirement	Choose
On-premises auth dependency acceptable	PTA

Authentication Method Selection

Scenario	Method
Highest security, phishing-resistant, no Windows device	FIDO2 security key
Windows device, biometric available	Windows Hello for Business
Mobile-first user, no hardware key	Microsoft Authenticator (passwordless)
Bootstrap MFA for new hire	Temporary Access Pass (TAP)
Break-glass admin account	TAP + FIDO2
Privileged roles needing phishing-resistant auth	FIDO2 or WHfB (Authentication Strength)

CA Grant Controls Reference

Grant Control	Use When
Require MFA	Any sensitive app — allows any MFA method
Require Authentication Strength: Phishing-resistant	Privileged roles, high-value apps — FIDO2/WHfB/CBA only
Require compliant device	Corporate data, Zero Trust device signal required
Require Hybrid Azure AD Joined	On-premises resource access, domain-joined devices
Require app protection policy	Mobile devices without MDM (MAM-only scenario)
Require Terms of Use	External users, compliance acknowledgement

Grant Control	Use When
Require password change	High user risk detected — force credential refresh
Block	High risk, blocked locations, legacy auth clients

Identity Protection Policy Reference

Situation	Correct Policy
Block sign-ins with high user risk	CA: user risk $\geq$ High $\rightarrow$ Block
Force password reset for high user risk	CA: user risk $\geq$ High $\rightarrow$ Require password change
Require MFA for medium sign-in risk	CA: sign-in risk $\geq$ Medium/High $\rightarrow$ Require MFA
Offline detection (impossible travel)	Only caught by user risk policy — sign-in risk won't catch it
Leaked credential detected	Only available with PHS $\rightarrow$ elevates user risk
False positive risk	Dismiss the risk (does NOT change password or revoke sessions)
Confirmed compromise	Confirm compromise $\rightarrow$ triggers additional controls

PIM Assignment Decision

Scenario	Assignment Type
Admin needs privileged role occasionally	Eligible
Break-glass account	Active (permanent, but in RMAU)
Short-term project (3 months)	Eligible (time-bound end date)
Service account, always needs Contributor	Active (time-bound, renewable)
All Global Admins	Eligible (max 2-4 active permanently)

App Permission Decision

Scenario	Permission Type
App reads signed-in user's calendar	Delegated — Calendar.Read
Background service reads ALL users' mail	Application — Mail.Read
User approves app to read their profile	Delegated — User.Read (user consent)
App needs to create users in the tenant	Application — User.ReadWrite.All (admin consent)
Daemon app needs no user interaction	Application (always admin consent)

Lifecycle Workflow Task Selection

Business Need	Built-in Task
New hire needs to set up MFA on day 1	Generate Temporary Access Pass
Terminated employee must lose all group access	Remove user from all groups
New hire needs to be in the All-Staff group	Add user to group
Leaver's account must be blocked immediately	Disable user account
30 days after termination, delete account	Delete user account
Non-SCIM system needs provisioning	Custom task extension (Logic App)

Access Review Decision

Scenario	Setting
Inactive guests need removal	Scope: Guest users only + No response = Deny
Stale group members across all users	Scope: All members + System recommendations

Scenario	Setting
Immediate enforcement on review close	Enable auto-apply results
Reviewers not responding	No response = Deny (not the default)
Guest cleanup after denial	"Block sign-in and delete after 30 days"

8. TOP 25 EXAM TRAPS {#exam-traps}

These are the highest-frequency gotchas on the SC-300 exam. Memorize all of them.

1. Authentication Strength ≠ Require MFA Requiring MFA allows any method including Authenticator push. Phishing-Resistant Authentication Strength only allows FIDO2, WHfB, and CBA. Authenticator push does NOT satisfy phishing-resistant strength.

2. PHS is the ONLY method enabling leaked credential detection PTA and Federation do not support leaked credential detection in Identity Protection. Always choose PHS when Identity Protection full fidelity is a requirement.

3. CA Report-Only does NOT enforce — it only logs A policy in Report-Only shows what WOULD have happened in sign-in logs but does not block or grant anything. Never skip this step before enabling production policies.

4. Managed identities cannot authenticate outside Azure They rely on the Azure IMDS service. For GitHub Actions, Kubernetes, AWS, or any non-Azure workload: use Workload Identity Federation with an app registration.

5. TAP is single-use and expires (default 1 hour) After a TAP is used to register a method, it cannot be reused. The user must register a permanent authentication method before the TAP expires.

6. PIM eligible ≠ PIM active A user with an eligible role has NO privileged access until they explicitly activate it. A user with an active role has access immediately. The exam constantly conflates these.

7. PIM for Entra roles and PIM for Azure roles are in different portals with different behaviors Entra roles: Entra ID blade. Azure roles: Azure portal → PIM → Azure resources. Different audit logs, different activation flows.

8. Access review auto-apply is NOT enabled by default Review results sit pending until manually applied unless you explicitly check "Auto apply results to resource." Without this,

denied access continues indefinitely.

9. "No response = Approve" is the dangerous default for access reviews Reviewers who don't respond leave access in place. Change to "No response = Deny" for security-sensitive reviews.

10. Connected organization ≠ Cross-tenant access policy Connected orgs = Entitlement Management (access packages for external users). Cross-tenant access = B2B collaboration and trust settings. These are completely separate configurations.

11. Lifecycle Workflows do NOT create AD accounts They run tasks on existing objects. Account creation is done by the provisioning service (Entra provisioning service + agent, or Connect Sync). LCW + provisioning are complementary.

12. Cloud Sync does NOT support group writeback, device writeback, or Exchange hybrid writeback Cloud Sync DOES support password writeback (with SSPR). This distinction is a constant exam target.

13. App Proxy Passthrough pre-auth = zero CA enforcement If pre-authentication is set to Passthrough, Conditional Access does not evaluate the request. Anyone with the external URL reaches the app's own login page directly.

14. Marking a named location as "trusted" does NOT bypass CA policies It reduces the sign-in risk score. It does NOT create a CA exclusion. To bypass CA, create an explicit exclusion in the CA policy.

15. Dynamic group -eq operator is case-sensitive for synced attributes "finance" ≠ "Finance" when synced from on-premises AD. Normalize attribute values in AD or use -match with regex if case inconsistency is unavoidable.

16. Dynamic group rule syntax error stops ALL evaluation for that group Not just the broken rule — the entire group stops updating. Monitor group processing errors in the portal.

17. Cloud Sync provisioning agent ≠ Connect provisioning agent Cloud Sync agent: syncs AD → Entra ID (replaces Connect Sync for lightweight scenarios). Connect provisioning agent: enables cloud-to-AD provisioning (e.g., Workday → AD). Different binaries, different purposes.

18. CA does NOT automatically block legacy authentication You must create an explicit policy targeting "Other clients" (Exchange ActiveSync, SMTP, IMAP, legacy Outlook). Without this, attackers can bypass MFA using legacy auth.

19. Only one active Entra Connect Sync server per tenant Additional Connect servers must be in staging mode. Running two active Connect servers causes sync conflicts. (Cloud Sync agents have no such limitation — multiple agents are supported for HA.)

20. RMAU blocks even Global Admins Objects in a Restricted Management AU cannot be modified by Global Admins unless they are explicitly scoped to that RMAU. This is by design, not a bug.

21. CAE revocation takes up to 15 minutes — not instant Near real-time is not the same as instant. Investigate access after 15+ minutes, not 5 minutes.

22. CAE only works with CAE-capable clients Legacy clients (SMTP, IMAP, old Outlook) don't support CAE. Their tokens remain valid until expiry (~60-90 min) regardless of account disable or session revocation.

23. Identity Protection risk policies (legacy) are deprecated in favor of CA risk conditions You should disable the legacy "User risk policy" and "Sign-in risk policy" in the Identity Protection blade and use CA policies with risk conditions instead for full control.

24. Dismissing a risk does NOT revoke sessions or change passwords If an account was actually compromised and you dismiss the risk instead of requiring a password change, the attacker may still have an active session.

25. Custom security attributes require BOTH Attribute Definition Administrator AND Attribute Assignment Administrator roles One role creates the attribute; a different role assigns values to users. Forgetting to grant assignment permissions means the attribute exists but no one can populate it.

9. COMPLETE LAB CHECKLIST {#labs}

Mark each lab complete before exam day. Every item below maps to a real exam question type.

Domain 1 Labs — User Identities

Hybrid Identity

- ☐ Install Entra Connect and configure Password Hash Sync
- ☐ Enable Pass-Through Authentication and compare behavior with PHS
- ☐ Configure Seamless SSO (enable in wizard + Group Policy for Intranet zone)
- ☐ Deploy Cloud Sync provisioning agent in a second forest
- ☐ Put a Connect server in staging mode and practice promotion (disable staging mode in wizard)
- ☐ Test accidental deletion prevention by triggering the threshold in a test environment

- ☐ Configure sync rule precedence in Synchronization Rules Editor

User & Group Management

- ☐ Create users (cloud-only and synced) and assign directory roles
- ☐ Create dynamic security group with multiple rule conditions
- ☐ Test case sensitivity of -eq vs -match in dynamic group rules
- ☐ Configure a standard Administrative Unit with scoped User Administrator
- ☐ Configure a dynamic AU with membership rule (user.country)
- ☐ Configure a Restricted Management AU — test that Global Admin cannot modify objects

External Identities

- ☐ Configure B2B collaboration (allow/deny list by domain)
- ☐ Set guest invite permissions to "Guest Inviter role only"
- ☐ Configure cross-tenant access (inbound/outbound) with a test partner tenant
- ☐ Configure inbound trust settings (trust MFA from partner tenant)
- ☐ Set up B2B Direct Connect (for Teams shared channels)
- ☐ Invite an external user and review the guest lifecycle

Custom Security Attributes

- ☐ Create a custom security attribute set
 - ☐ Define an attribute within the set
 - ☐ Assign Attribute Definition Admin role to a user
 - ☐ Assign Attribute Assignment Admin role to a different user
 - ☐ Assign attribute values to users and verify visibility restrictions
-

Domain 2 Labs — Authentication & Access Management

Conditional Access

- ☐ Create "Require MFA for all users" baseline policy (Report-Only first, then Enabled)
- ☐ Create "Block legacy authentication" policy (Other clients condition)
- ☐ Create CA policy with named location condition (block specific countries)
- ☐ Create CA policy with device filter (exclude compliant devices from MFA)
- ☐ Create CA policy with Authentication Strength: Phishing-resistant for privileged roles
- ☐ Configure sign-in frequency (set to 4 hours for admin roles)
- ☐ Configure persistent browser session (test behavior on browser close)
- ☐ Create CA policy targeting a service principal (workload identity)
- ☐ Test Report-Only mode by reviewing sign-in logs for What-If results

Authentication Methods

- ☐ Enable and configure Microsoft Authenticator (passwordless phone sign-in)
- ☐ Register a FIDO2 security key (if hardware available, otherwise review docs)
- ☐ Configure FIDO2 key restrictions (AAGUID allowlist)
- ☐ Configure Windows Hello for Business (cloud trust model for hybrid)
- ☐ Create a Temporary Access Pass for a test user
- ☐ Test TAP single-use behavior (attempt second use after first)
- ☐ Configure Authentication Methods policy (enable/disable per method)

Identity Protection

- ☐ Review the Risky Users report and Risky Sign-ins report
- ☐ Dismiss a risk detection — confirm password NOT changed
- ☐ Remediate a risk (force password reset) — confirm risk clears
- ☐ Configure CA policy with user risk condition (High → Block)
- ☐ Configure CA policy with sign-in risk condition (Medium → Require MFA)
- ☐ Confirm compromise for a test user — observe elevated risk
- ☐ Disable legacy Identity Protection risk policies (use CA instead)

CAE & Token Protection

- ☐ Enable CAE (verify it's enabled by default in modern tenants)
 - ☐ Disable a user and measure how long before access is blocked in Exchange Online
 - ☐ Enable token protection on a CA session control and test with a supported app
-

Domain 3 Labs — Workload Identities & App Access

App Registrations

- ☐ Register a new application in Entra ID
- ☐ Add delegated API permissions (Microsoft Graph → User.Read)
- ☐ Add application API permissions (Microsoft Graph → User.ReadWrite.All) — observe admin consent requirement
- ☐ Grant admin consent tenant-wide for application permission
- ☐ Create a client secret (note expiry) — then delete and replace with certificate
- ☐ Configure redirect URIs for authorization code flow
- ☐ Configure Workload Identity Federation (GitHub Actions as external IdP)

Enterprise Applications

- ☐ Configure SAML SSO for a test application (or gallery app)
- ☐ Configure OIDC SSO for a test application
- ☐ Configure SCIM provisioning to an enterprise app (use a gallery app with SCIM support)
- ☐ Assign users and groups to an enterprise application
- ☐ Configure admin consent workflow — set designated reviewers
- ☐ Submit a consent request as a test user — approve as reviewer

Application Proxy

- ☐ Install App Proxy connector on a Windows Server (on-premises or VM)
- ☐ Create a connector group and assign the connector
- ☐ Publish an internal web app with Entra pre-authentication
- ☐ Publish a second app with Passthrough pre-authentication — observe CA is not enforced
- ☐ Configure KCD for an IIS app (create SPN, delegate in AD)
- ☐ Configure header-based SSO for an App Proxy application

Managed Identities

- ☐ Enable system-assigned managed identity on an Azure VM
 - ☐ Assign Storage Blob Data Reader role to the system-assigned identity
 - ☐ Create a user-assigned managed identity
 - ☐ Assign the user-assigned identity to multiple Azure resources
 - ☐ Assign Key Vault Secrets User role to the user-assigned identity
 - ☐ Retrieve a secret from Key Vault using the managed identity token (via VM/function)
-

Domain 4 Labs — Identity Governance

Entitlement Management

- ☐ Create a catalog and add resources (group, app, SharePoint site)
- ☐ Create an access package with approval policy (2-stage approval)
- ☐ Configure access package lifecycle (90-day expiration, quarterly access review)
- ☐ Register a connected organization (external partner tenant)
- ☐ Create a policy for users not in your directory (external requestors via connected org)
- ☐ Configure incompatible access packages (SoD enforcement)
- ☐ Request an access package as a test user — approve as approver

Access Reviews

- ☐ Create a group access review (all members, 30-day duration, weekly recurrence)
- ☐ Create a guest-only access review with "No response = Deny"
- ☐ Enable auto-apply results on a review — verify immediate effect on close
- ☐ Create an app assignment review
- ☐ Create a PIM role access review (eligible role review)
- ☐ Test denial outcomes: group removal, app removal, guest block+delete

PIM

- ☐ Assign a user as Eligible for User Administrator role
- ☐ Configure activation settings: MFA + justification + approval + 4-hour max duration
- ☐ Activate the role as the eligible user — complete the full activation flow
- ☐ Test approval timeout — observe auto-denial when approver doesn't respond
- ☐ Assign PIM for Azure roles (Contributor on a subscription, eligible)
- ☐ Activate Azure role and compare flow to Entra role activation
- ☐ Review PIM audit logs — identify who activated what and when
- ☐ Review PIM alerts — identify "too many permanent assignments"

Lifecycle Workflows

- ☐ Create a Joiner workflow triggered 7 days before employeeHireDate
- ☐ Add tasks: Generate TAP, Send welcome email, Add to group
- ☐ Create a Leaver workflow triggered on last day of employment
- ☐ Add tasks: Remove from all groups, Disable account, Send offboarding email
- ☐ Create a Mover workflow triggered by department attribute change
- ☐ Create a custom task extension pointing to a Logic App
- ☐ Run a workflow on-demand for a test user — verify task execution

Terms of Use

- ☐ Create a Terms of Use policy (upload a sample PDF)
 - ☐ Assign Terms of Use to a CA policy targeting guest users
 - ☐ Sign in as a guest user — accept Terms of Use
 - ☐ Review acceptance records in the portal
-

Advanced Labs (Gap Coverage)

- ☐ Configure Authentication Strength: custom strength requiring FIDO2 only
- ☐ Create CA policy with device filter (exclude PAW devices from MFA requirement)

- ☐ Configure FIDO2 key restriction by AAGUID
 - ☐ Test soft match during initial Connect Sync setup
 - ☐ Test hard match (set ImmutableID to recover broken sync)
 - ☐ Configure WHfB Cloud Trust hybrid deployment
 - ☐ Test access package SoD enforcement (attempt to hold incompatible packages)
 - ☐ Test Workload Identity Federation (GitHub Actions exchanging OIDC token for Entra token)
 - ☐ Configure RMAU and test Global Admin block behavior
-
-

10. COMPLETE DOCUMENTATION MAP {#docs}

Every link is the primary Microsoft Learn source for that topic. Bookmark these and use them as your reading list alongside the corresponding section in this document.

Domain 1 — User Identities

Topic	Link
Entra Connect overview	https://learn.microsoft.com/entra/identity/hybrid/connect/whatis
Password Hash Sync	https://learn.microsoft.com/entra/identity/hybrid/connect/how-to-connect-password-hash-synchronization
Pass-Through Authentication	https://learn.microsoft.com/entra/identity/hybrid/connect/how-to-connect-pta
Federation (AD FS)	https://learn.microsoft.com/entra/identity/hybrid/connect/how-to-connect-fed
Choose authentication method	https://learn.microsoft.com/entra/identity/hybrid/connect/choose-ad-authn
Cloud Sync overview	https://learn.microsoft.com/entra/identity/hybrid/cloud-sync/what-is-cloud-sync
Staging server	https://learn.microsoft.com/entra/identity/hybrid/connect/how-to-connect-sync-staging-server

Topic	Link
Accidental deletion prevention	https://learn.microsoft.com/entra/identity/hybrid/connect/how-to-connect-sync-feature-prevent-accidental-deletes
Duplicate attribute resiliency	https://learn.microsoft.com/entra/identity/hybrid/connect/how-to-connect-syncservice-duplicate-attribute-resiliency
Dynamic groups	https://learn.microsoft.com/entra/identity/users/groups-dynamic-membership
Administrative units	https://learn.microsoft.com/entra/identity/role-based-access-control/administrative-units
Restricted Management AUs	https://learn.microsoft.com/entra/identity/role-based-access-control/admin-units-restricted-management
External Identities overview	https://learn.microsoft.com/entra/external-id/
Cross-tenant access settings	https://learn.microsoft.com/entra/external-id/cross-tenant-access-overview
B2B allow/deny list	https://learn.microsoft.com/entra/external-id/allow-deny-list
Custom security attributes	https://learn.microsoft.com/entra/fundamentals/custom-security-attributes-overview
Workday inbound provisioning	https://learn.microsoft.com/entra/identity/saas-apps/workday-inbound-tutorial
Stale guest cleanup	https://learn.microsoft.com/entra/identity/users/clean-up-stale-guest-accounts
Seamless SSO	https://learn.microsoft.com/entra/identity/hybrid/connect/how-to-connect-ssu

Domain 2 — Authentication & Access Management

Topic	Link
Conditional Access	https://learn.microsoft.com/entra/identity/conditional-access/overview

Topic	Link
overview	
CA policy components	https://learn.microsoft.com/entra/identity/conditional-access/concept-conditional-access-policies
Authentication Strengths	https://learn.microsoft.com/entra/identity/authentication/concept-authentication-strengths
Device filter conditions	https://learn.microsoft.com/entra/identity/conditional-access/concept-condition-filters-for-devices
Named locations	https://learn.microsoft.com/entra/identity/conditional-access/location-condition
Token protection	https://learn.microsoft.com/entra/identity/conditional-access/concept-token-protection
CA for workload identities	https://learn.microsoft.com/entra/identity/conditional-access/workload-identity
Continuous Access Evaluation	https://learn.microsoft.com/entra/identity/conditional-access/concept-continuous-access-evaluation
Authentication methods overview	https://learn.microsoft.com/entra/identity/authentication/concept-authentication-methods
Passwordless authentication	https://learn.microsoft.com/entra/identity/authentication/concept-passwordless
FIDO2 security keys	https://learn.microsoft.com/entra/identity/authentication/howto-authentication-passwordless-security-key
WHfB Cloud Trust deployment	https://learn.microsoft.com/entra/identity/authentication/howto-windows-hello-for-business-deploy-cloud-trust
Temporary Access Pass	https://learn.microsoft.com/entra/identity/authentication/howto-authentication-temporary-access-pass
Microsoft Authenticator passwordless	https://learn.microsoft.com/entra/identity/authentication/howto-authentication-passwordless-phone
Azure MFA overview	https://learn.microsoft.com/entra/identity/authentication/concept-mfa-howitworks

Topic	Link
Identity Protection overview	https://learn.microsoft.com/entra/id-protection/overview-identity-protection
Risk detections	https://learn.microsoft.com/entra/id-protection/concept-identity-protection-risks

Domain 3 — Workload Identities & App Access

Topic	Link
App registrations overview	https://learn.microsoft.com/entra/identity-platform/concept-register-app
Permissions and consent	https://learn.microsoft.com/entra/identity-platform/permissions-consent-overview
Certificates and secrets	https://learn.microsoft.com/entra/identity-platform/concept-certificates-secrets
Admin consent workflow	https://learn.microsoft.com/entra/identity-platform/howto-configure-admin-consent-workflow
Enterprise apps overview	https://learn.microsoft.com/entra/identity/enterprise-apps/what-is-application-management
SSO options	https://learn.microsoft.com/entra/identity/enterprise-apps/sso-options
SCIM provisioning	https://learn.microsoft.com/entra/identity/app-provisioning/use-scim-to-provision-users-and-groups
App Proxy overview	https://learn.microsoft.com/entra/identity/app-proxy/application-proxy
App Proxy connector deployment	https://learn.microsoft.com/entra/identity/app-proxy/application-proxy-deploy-connector
App Proxy connector groups	https://learn.microsoft.com/entra/identity/app-proxy/application-proxy-connector-groups
Managed identities overview	https://learn.microsoft.com/entra/identity/managed-identities-azure-resources/overview

Topic	Link
Workload identity federation	https://learn.microsoft.com/entra/workload-id/workload-identity-federation

Domain 4 — Identity Governance

Topic	Link
Entitlement management overview	https://learn.microsoft.com/entra/id-governance/entitlement-management-overview
Access packages	https://learn.microsoft.com/entra/id-governance/entitlement-management-access-packages
Catalogs	https://learn.microsoft.com/entra/id-governance/entitlement-management-catalogs
Connected organizations	https://learn.microsoft.com/entra/id-governance/entitlement-management-connected-orgs
Incompatible access packages (SoD)	https://learn.microsoft.com/entra/id-governance/entitlement-management-access-package-incompatible
Access reviews overview	https://learn.microsoft.com/entra/id-governance/access-reviews-overview
Access reviews for business apps	https://learn.microsoft.com/entra/id-governance/access-reviews-business-apps
PIM overview	https://learn.microsoft.com/entra/id-governance/privileged-identity-management/pim-configure
PIM — Assign eligible roles	https://learn.microsoft.com/entra/id-governance/privileged-identity-management/pim-resource-roles-assign-roles
Lifecycle Workflows overview	https://learn.microsoft.com/entra/id-governance/workflows-overview
Terms of Use	https://learn.microsoft.com/entra/id-governance/terms-of-use

Official Exam Resources

Resource	Link
SC-300 Official Study Guide (2026)	https://learn.microsoft.com/credentials/certifications/resources/study-guides/sc-300
SC-300 Free Practice Assessment	https://learn.microsoft.com/credentials/certifications/exams/sc-300/practice/assessment?assessmentId=61
SC-300 Microsoft Learn Path	https://learn.microsoft.com/training/courses/sc-300t00
Exam Ref SC-300 (Microsoft Press)	https://www.microsoftpressstore.com/store/exam-ref-sc-300-microsoft-identity-and-access-administrator-9780137886593
Microsoft Entra ID Documentation Hub	https://learn.microsoft.com/entra/
Microsoft Identity Platform Docs	https://learn.microsoft.com/entra/identity-platform/

Final Exam Day Checklist

- ☐ All 4 domain sections reviewed
- ☐ All 25 exam traps memorized
- ☐ All Quick-Reference tables reviewed
- ☐ Practice assessment score $\geq 80\%$ on two separate attempts
- ☐ Labs completed for every feature you felt uncertain about
- ☐ This document read end-to-end at least once before exam day

This document combines: SC-300 4-Week Study Plan + SC-300 Exam Cheat Sheet + SC-300 Lab Checklist + SC-300 Documentation Map + SC-300 Depth Gap-Fill Guide. All content aligned with 2025-2026 exam objectives.

Cross-reference with the official study guide at:

<https://learn.microsoft.com/credentials/certifications/resources/study-guides/sc-300>